Powering Innovation That Drives Human Advancement

Addressing cybersecurity in Automotive with medini analyze

Mario Winkler / Lead Product Manager

23.08.2024

©2024 ANSYS, Inc.

Powering innovation that drives human advancement

50 YEARS OF INNOVATION

#1 IN ENGINEERING SIMULATION SOFTWARE

Shatter Records

Unlock Possibilities

Make the Unmakeable

Save Lives

©2024 ANSYS, Inc.

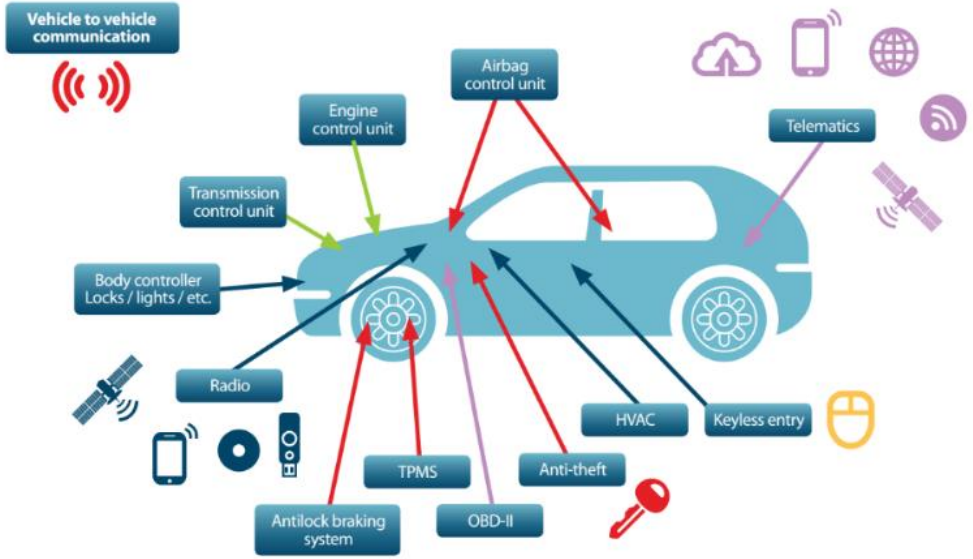
Agenda

- Motivation
- Generic Terminology
- ISO/SAE 21434 Risk Assessment Activities
- ISO/SAE 21434 Terminology
- Current Tool Support
- Model-based Tool Support with Ansys medini™ analyze for Cybersecurity - a Demo
- Conclusion

©2024 ANSYS, Inc.

Why pay more attention to Cyber Security?

- Cyber-physical systems are permanent target for malicious attacks
- More complex and bigger code increases the number of vulnerabilities – cars have hundreds of (connected) ECUs
- Increased connectivity increases attack surfaces - flashed firmware, Bluetooth, WiFi, cellular, GPS, …
- An attacker can trigger a fault when he wants to: Steering, Braking, Powertrain,…
- Successful attacks can lead to various damages
  - Compromised safety
  - Unavailability of systems
  - Loss of data
  - Loss of privacy
  - Financial loss
  - Loss of reputation



©2024 ANSYS, Inc.

Major Cyber Attacks That Target Automotive

- **735 significant incidents world-wide in this year**
- exploiting:
  - Key fobs
  - Mobile apps and remote controls
  - Wi-Fi/BT vulnerabilities
  - GPS Spoofing
  - Server hacking

https://socradar.io/major-cyber-attacks-targeting-the-automotive-industry/

https://xiphcyber.com/articles/automotive-hacking

©2024 ANSYS, Inc.

Cybersecurity analysis and management

Why is Cybersecurity analysis and management important?

- Without appropriate analysis, countermeasures and continuous management there are huge risks incl. safety, privacy, financial, legal
- Obligation to comply to recent cybersecurity standards and regulations
- Cybersecurity risks can pop-up any time in a product’s lifecycle -> it is a continuous activity with high management requirements

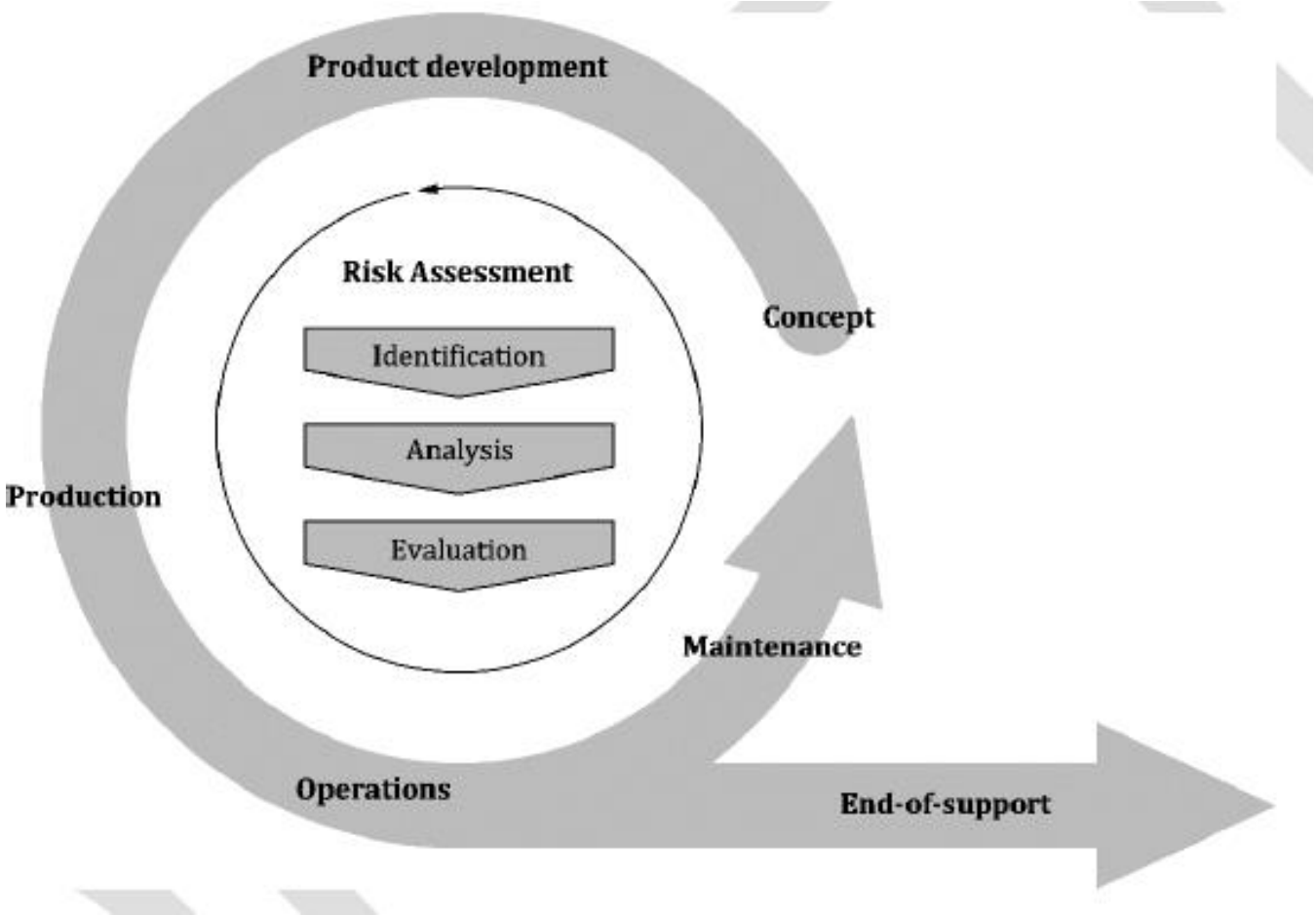
©2024 ANSYS, Inc.

Generic Terminology

©2024 ANSYS, Inc.

ISO/SAE 21434 Risk Management Framework

- an iterative process
- needs to be applied on any stage in the product‘s lifecycle



©2024 ANSYS, Inc.

ISO/SAE 21434 - Risk Assessment Methods

- Determine the extent to which a stakeholder can be impacted by a threat scenario
- Activities are:
  a. identify assets, their cybersecurity properties and their damage scenarios
  b. rate the impact of the identified damage scenarios
  c. identify threat scenarios
  d. identify the attack paths that realize a threat scenario
  e. assess the ease with which identified attack paths can be exploited (feasibility)
  f. determine the risk value of a threat scenario
  g. select the appropriate risk treatment options.

What to protect? How can it be damaged?

How severe is the damage?

What could *potentially* lead to the damage?

What are the actions to realize it?

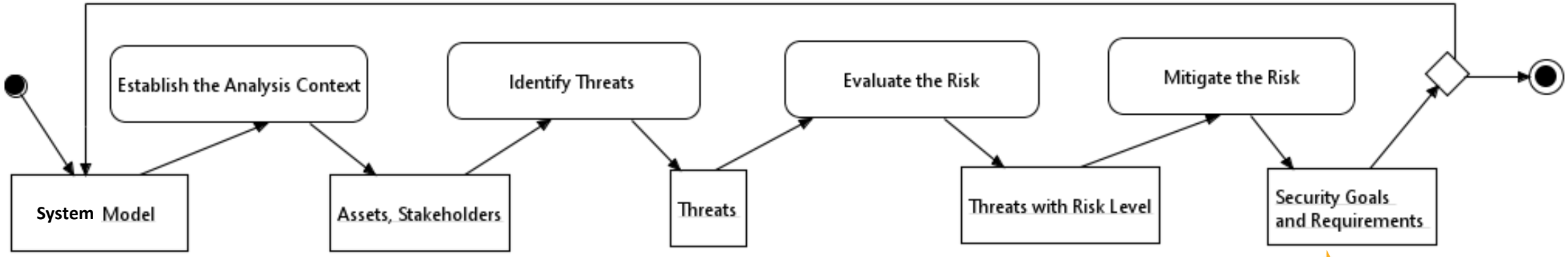
How difficult is it to execute the attack?

Based on the above, what is the risk level?

What do we do with the risk?

©2024 ANSYS, Inc.

Typical Stages in Cyber Security Process



Description of the system that we analyze: functions, components, ports, connections, data,..

What needs to be protected? Why (What are the stakeholder interests)?

What potential dangers exist that might lead to harm in case of an attack?

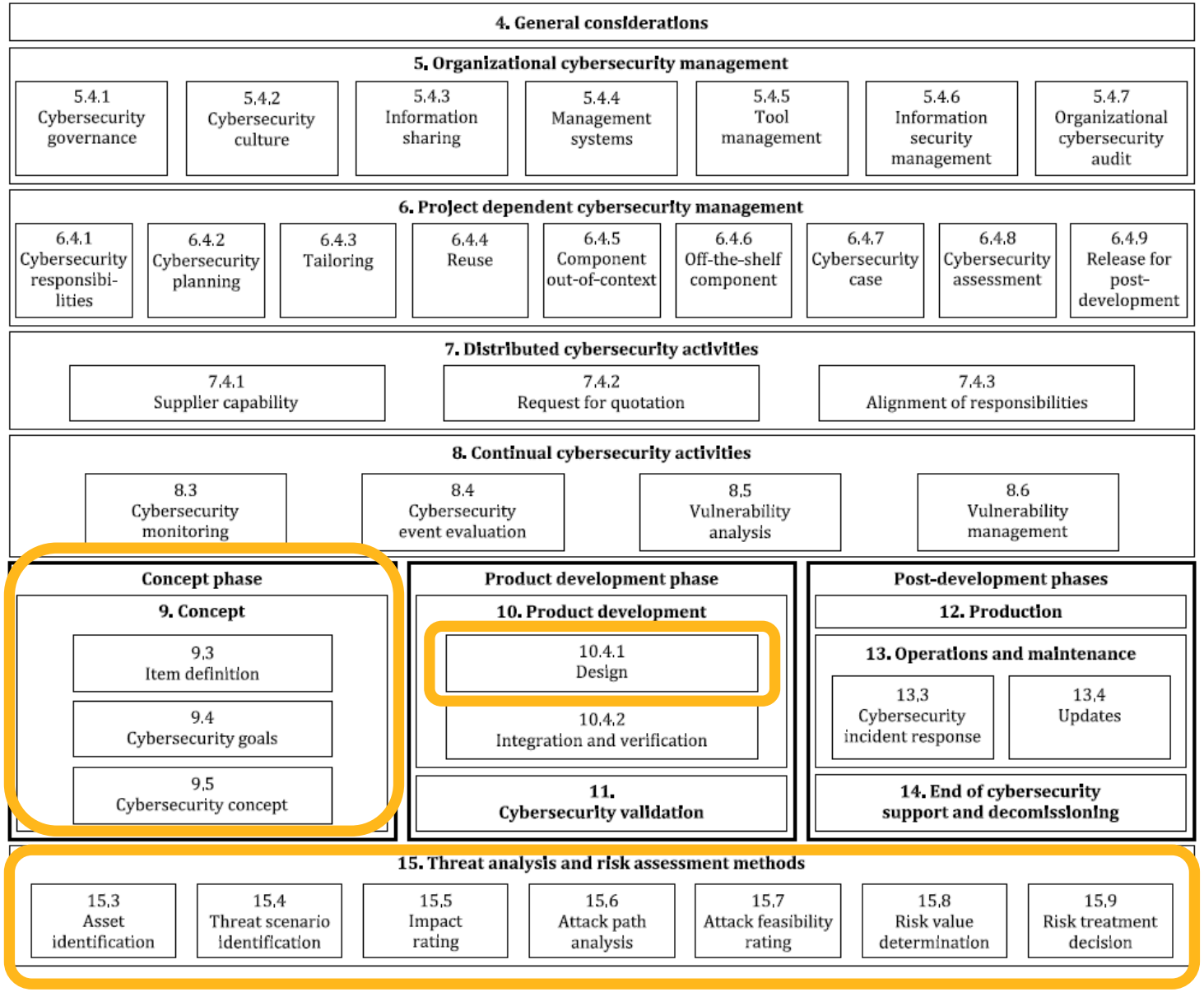
What is the risk of a threat (consequences, likelyhood of being excuted)?

How shall the risk be mitigated?

©2024 ANSYS, Inc.

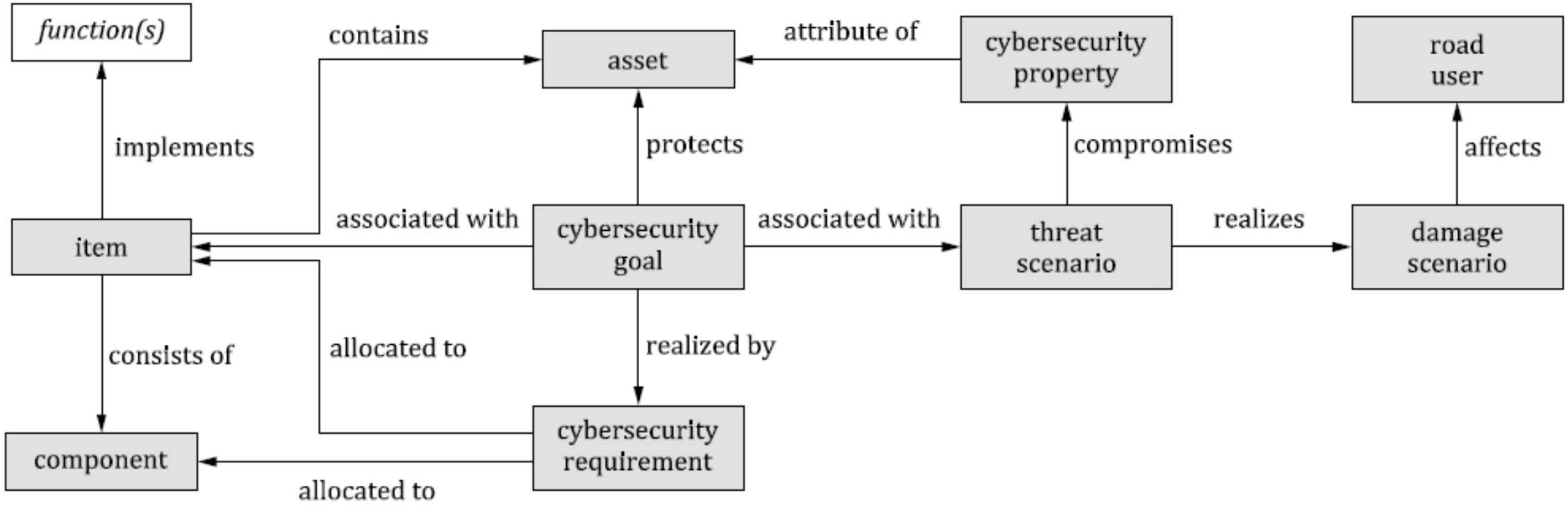
ISO/SAE 21434 Structure

- Risk assessment methods that are currently in scope of medini analyze



©2024 ANSYS, Inc.

ISO/SAE 21434 – Concepts and their relations

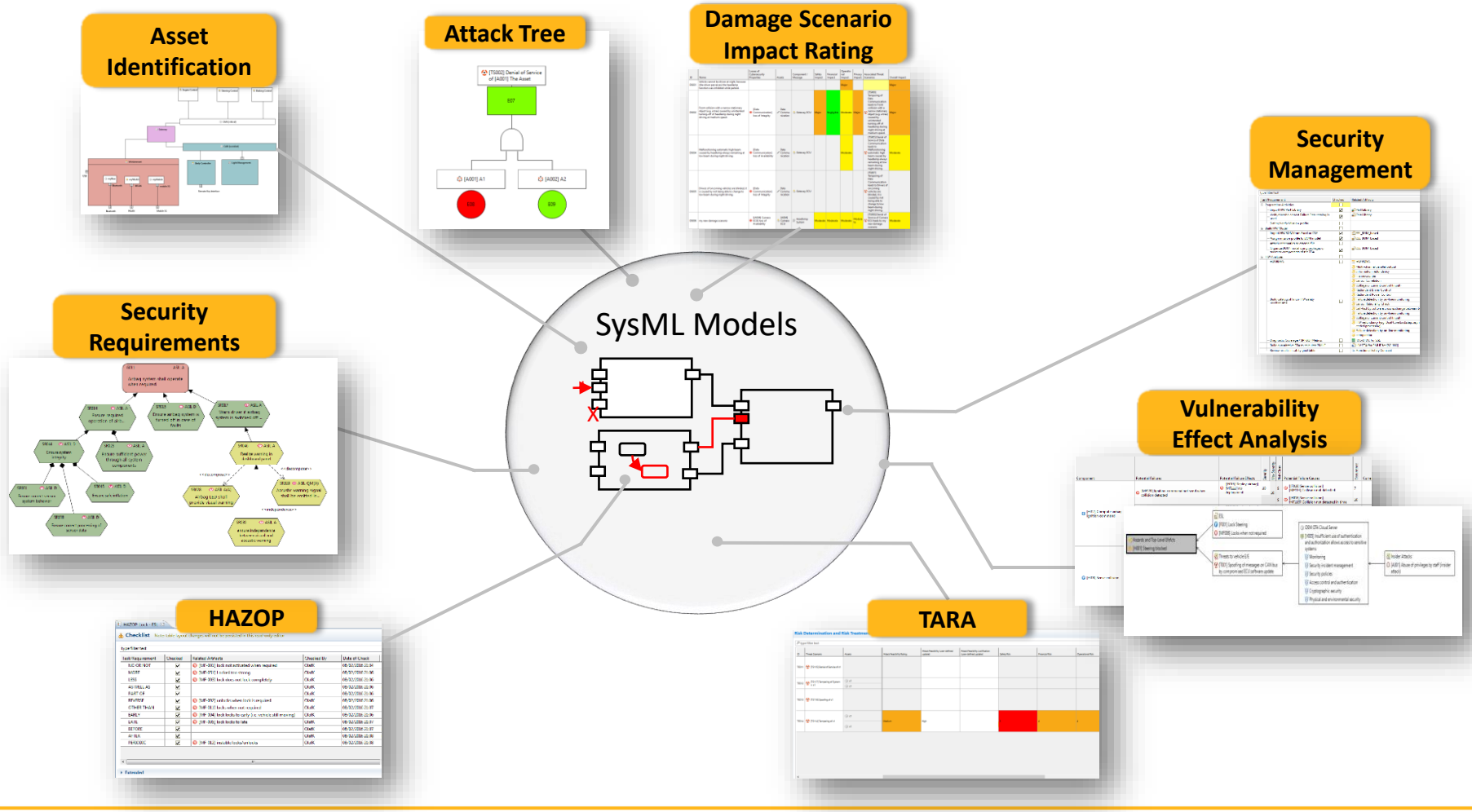


©2024 ANSYS, Inc.

Traditional approach: Point Tools for individual Tasks

©2024 ANSYS, Inc.

A Model-Based Approach Helps to Streamline



Model-based approach ensures unrivalled level of consistency, traceability and efficiency

©2024 ANSYS, Inc.

a) Assets and Security Properties

- The system under assessment needs to be defined
- ISO/SAE 21434 defines this as an Item (similar to ISO 26262)
- Assets to be protected must be identified
  - "*Something* for which the compromise of its cybersecurity properties can lead to damage to an items stakeholder"
    - inputs or outputs
    - in cyberspace as well as in physical world
    - data consumed or generated
    - they don't need to be physical but could be more conceptual elements of an item
- Assets have security properties
  - "Including confidentiality, integrity, and availability"

©2024 ANSYS, Inc.

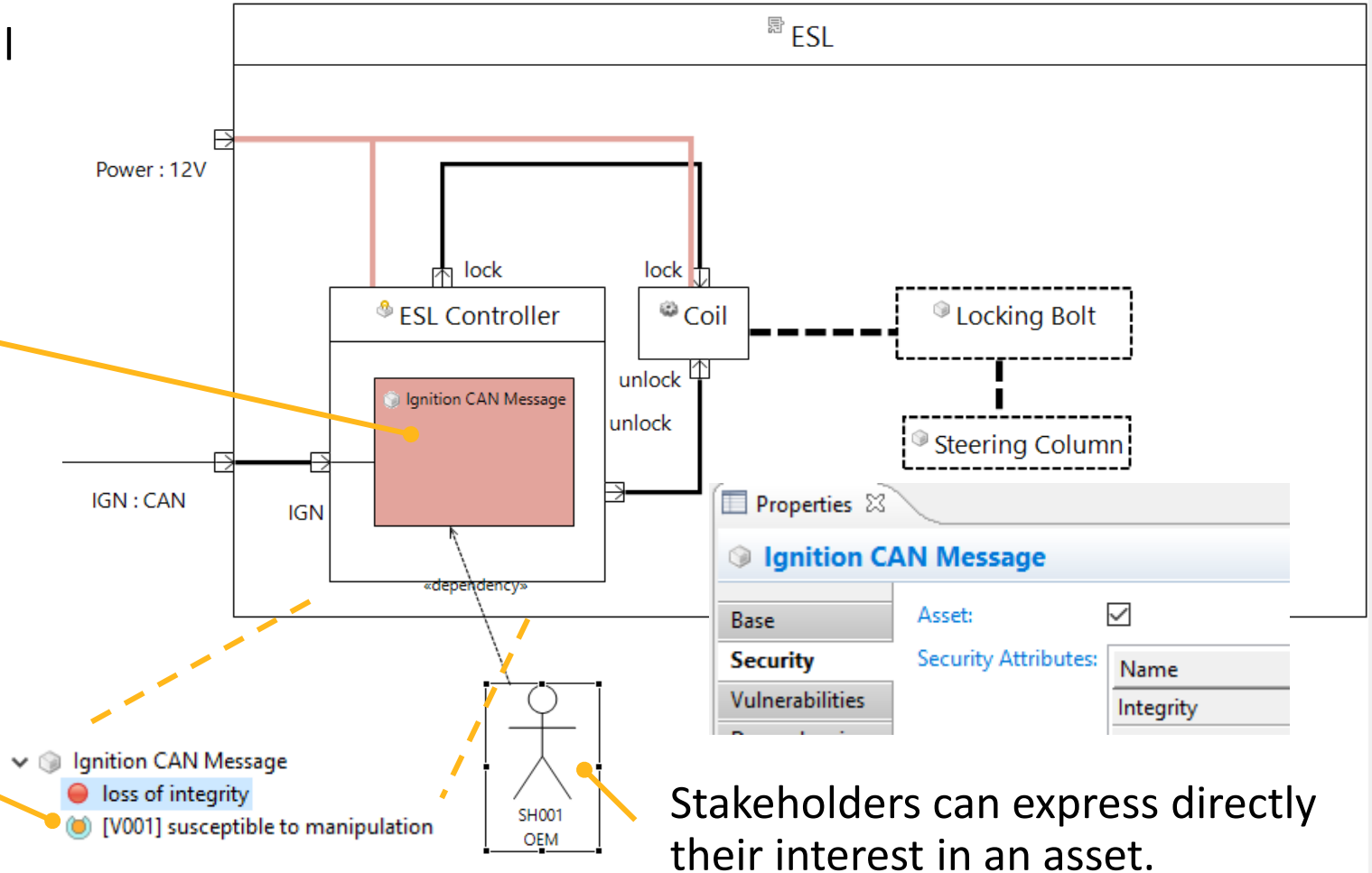
medini analyze – Items, Assets and Security Properties

Assets are not necessarily architectural components - rather data objects like messages, firmware, etc.

- Could be allocated to architectural components/functions or can be contained by them

Cybersecurity properties are annotated at their asset and their losses are explicitly modelled

Additionally, assets could express their vulnerabilities



Stakeholders can express directly their interest in an asset.

©2024 ANSYS, Inc.

a) Damage Scenario

- Adverse consequence or undesirable result due to the compromise of a cybersecurity of an asset
- it must outline:
  - detailed description of affected road users
  - explain harm that may come to those users

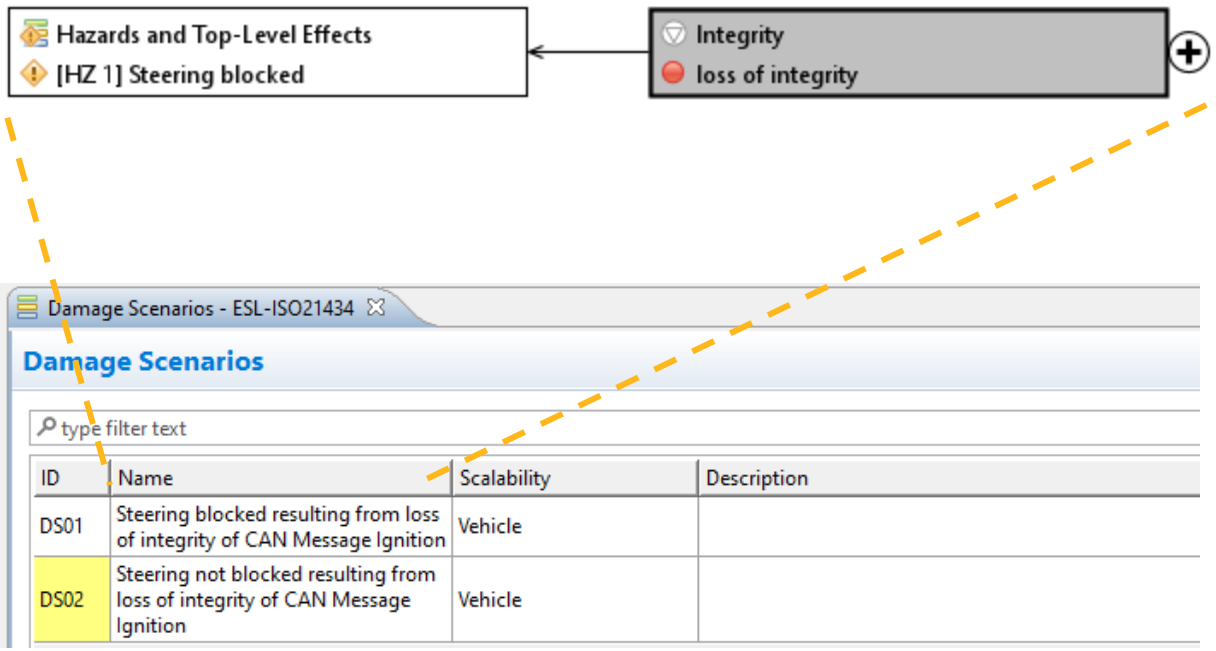
Table G.2 - Example of a list of assets and damage scenarios created by Company A

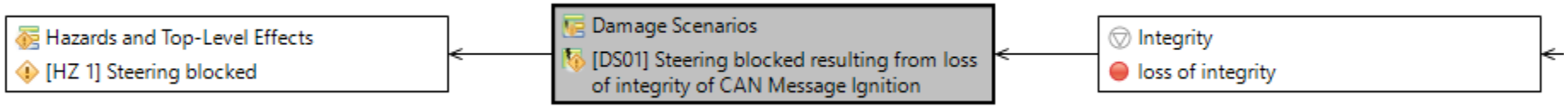
Component/ Message	Function	Asset	Cyber Security Property			Damage Scenario No.	Damage Scenario	Identified Asset for Safety
			C	I	A			
Navigation ECU	…	N/A	…	…	…	N/A	N/A	
Gateway ECU	…	N/A	…	…	…	N/A	N/A	
Body Control ECU	Power switch control function	Firmware	-	X	X	…	…	
	CAN message transmission function	CAN Frame	-	X	X	xx	Unintended headlamp's turn off during IGN switch's turn off, resulting from loss of integrity of CAN signal	X
						D.x	Unintended headlamp's turn off during night driving resulting from loss of integrity of CAN signal	X
						:	.	
	…	…	…	…	…	…	…	
Power Switch Actuator	Headlamp control function	Firmware	…	…	…	…	…	X

©2024 ANSYS, Inc.

medini analyze - Damage Scenario

- Damage Scenarios are the result of the loss of a cybersecurity property causing a (safety) hazard modelled in the Cause/Effect net
- in case the Damage Scenario is safety related it represents the cause-relation between the loss of a cybersecurity property and a safety hazard





©2024 ANSYS, Inc.

b) Damage Scenario Impact Analysis

- Negative impact of a damage scenario on road users is rated
- Minimum are Safety, Financial, Operational, Privacy dimensions
- Common Scale in each dimension: Negligible, Moderate, Major, Severe
- None is used when a rating dimension is not applicable

5	[Optional] "Critical"	ASIL D
4	Severe	ASIL C
3	Major	ASIL B
2	Moderate	ASIL A
1	Negligible	QM
0	None	Not safety relevant

Safety

4	Severe	The operational damage leads to a vehicle not working, from non-intended operation up to the vehicle being non-operational
3	Major	The operational damage leads to the loss of a vehicle function
2	Moderate	The operational damage leads to partial degradation of a vehicle function or performance
1	Negligible	The operational damage leads to no effect or indiscernible degradation of a vehicle function or performance
0	None	Not operations relevant

Operational

ISO/SAE 21434 Annex H Table H.3

4	Severe	Loss of data considered private by government regulation
3	Major	Loss of data only considered private by company policy
2	Moderate	Loss of potentially linkable data
1	Negligible	Loss of non-linkable data
0	None	No data loss

Privacy

Tailored Example

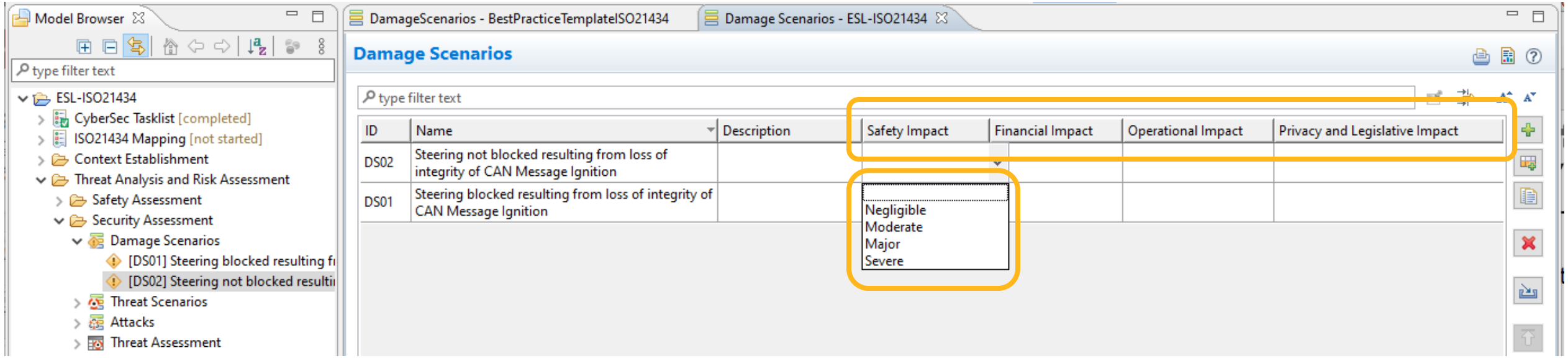
4	Severe	The financial damage leads to catastrophic consequences that the road user might not overcome
3	Major	The financial damage leads to substantial consequences that the road user will be able to overcome
2	Moderate	The financial damage leads to inconvenient consequences that the road user will be able to overcome with limited resources
1	Negligible	The financial damage leads to no effect, negligible consequences, or is irrelevant to the stakeholder
0	None	Not financially relevant

Financial

ISO/SAE 21434 Annex H Table H.2

©2024 ANSYS, Inc.

medini analyze – Impact Rating



©2024 ANSYS, Inc.

medini analyze – Impact Rating

Damage Scenarios - Impact Rating - Headlamp System - ISO21434 Example

Damage Scenarios - Impact Rating

FMEDA C

type filter text

Damage Scenario	Description / Scalability	Assets	Losses	Stakeholder	Safety Impact per Stakeholder	Financial Impact per Stakeholder	Operational Impact per Stakeholder	Privacy Impact per Stakeholder
[DS001] Vehicle cannot be driven at night, because (the driver perceives) the headlamp function was inhibited while parked.	Scalability: none	[A001] Lamp Request (low, high, or off)	[[A001] Lamp Request (low, high, or off)] loss of Integrity [[A001] Lamp Request (low, high, or off)] loss of Availability				Major	
[DS002] Front collision with a narrow stationary object (e.g. a tree) caused by unintended turning-off of headlamp during night driving at medium speed.	Scalability: none	[A001] Lamp Request (low, high, or off)	[[A001] Lamp Request (low, high, or off)] loss of Integrity [[A001] Lamp Request (low, high, or off)] loss of Authenticity		Negligible Moderate Major Severe			

©2024 ANSYS, Inc.

c) Threat Scenarios

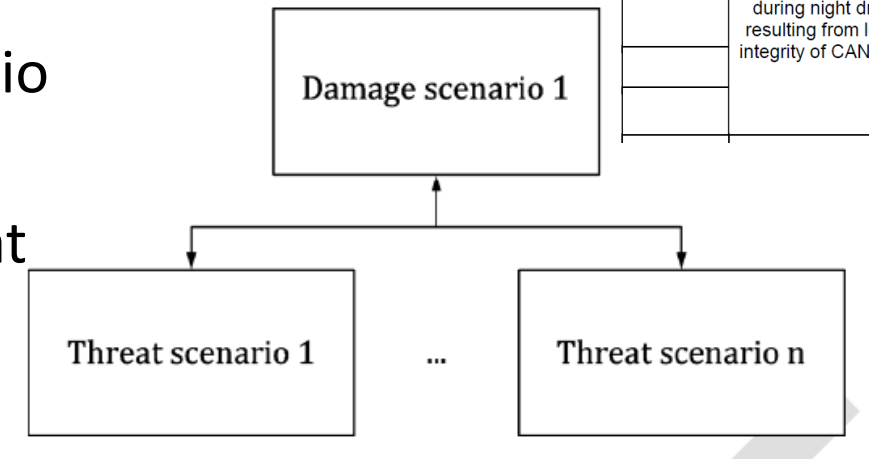
- Threat Scenario is a statement of potential negative actions that lead to a damage scenario
- identifiable by brainstorming or by approaches like STRIDE
- can include targeted asset, compromised cybersecurity properties and the action to accomplish a damage scenario
- one damage scenario can correspond to multiple threat scenarios

Table G.7 - Example of a list of threat scenarios created by Company B

Damage Scenario	Threat Scenario
Unexpected loss of head light	The lamp switch off request message could be spoofed.
Unable to switch off head light	The CAN bus could be flooded with higher priority messages, so that the lamp switch off request may be processed with significant delay.

Table G.6 - Example of a list of threat scenarios created by Company A

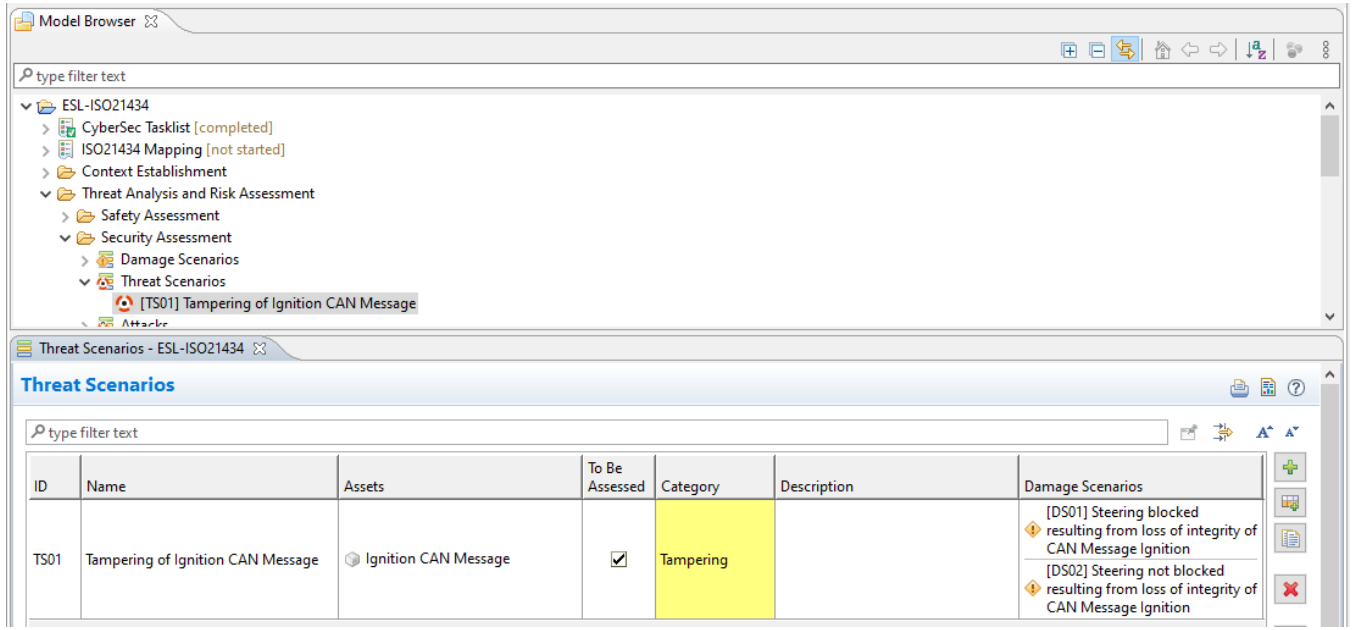
Damage Scenario No.	Damage Scenario	Threat Scenario	Threat Scenario No.
:	:	:	:
D.x	Unintended headlamp's turn off during night driving resulting from loss of integrity of CAN signal	Spoofing of a signal leads to loss of integrity of the CAN message of "Lamp Request" signal of Power Switch Actuator ECU potentially causing unintended headlamp's turn off during night driving resulting from loss of integrity of CAN signal	T.x
		Tampering of a signal sent by Body Control ECU leads to ….	T.y
		….	…

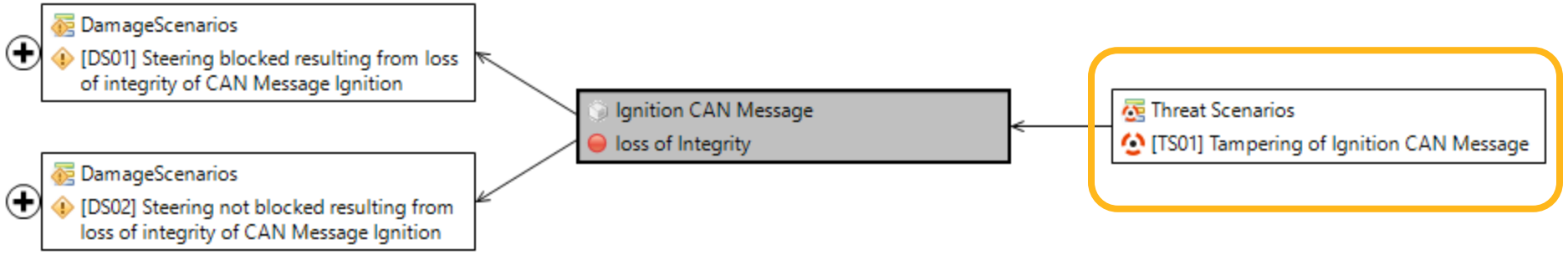


©2024 ANSYS, Inc.

medini analyze - Threat Scenarios

- Threat Scenarios are modelled explicitely
- Can automatically be derived by applying the STRIDE method on the security properties of the assets
- A cause relation to the loss of the cybersecurity property is set up





©2024 ANSYS, Inc.

d) Attack Path Analysis

Attack Path

- is a set (sequence) of actions that could lead to the realization of a threat scenario
- could be interpreted as sequence of attacks

Table G.8 - Example of a list of attack paths for each threat scenario created by Company A

Threat Scenario No.	Threat Scenario	Attack Path No.	Attack Path
T.x	Spoofing of a signal leads to loss of integrity of the CAN message of "Lamp Request" signal of Power Switch Actuator ECU	AP.x	An attacker compromise Navigation ECU from Cellular interface
			Compromised Navigation ECU transmits malicious control signals
			Gateway ECU forward the malicious signals to Power Switch Actuator
			The malicious signals spoof the lamp switch on request
		AP.y	An attacker compromise Navigation ECU from Bluetooth interface
			Compromised Navigation ECU transmits malicious control signals
			Gateway ECU forward the malicious signals to Power Switch Actuator
			The malicious signals spoof the lamp switch on request
		AP.z	An attacker sends malicious control signals from OBD2 connector
			Gateway ECU forward the malicious signals to Power Switch Actuator
			The malicious signals spoof the lamp switch on request

©2024 ANSYS, Inc.

d) Attack Path Analysis

Determination of attack path

- top-down (deductive) starting from the threat scenario
- bottom-up (inductive) where attack paths are built from identified vulnerabilities

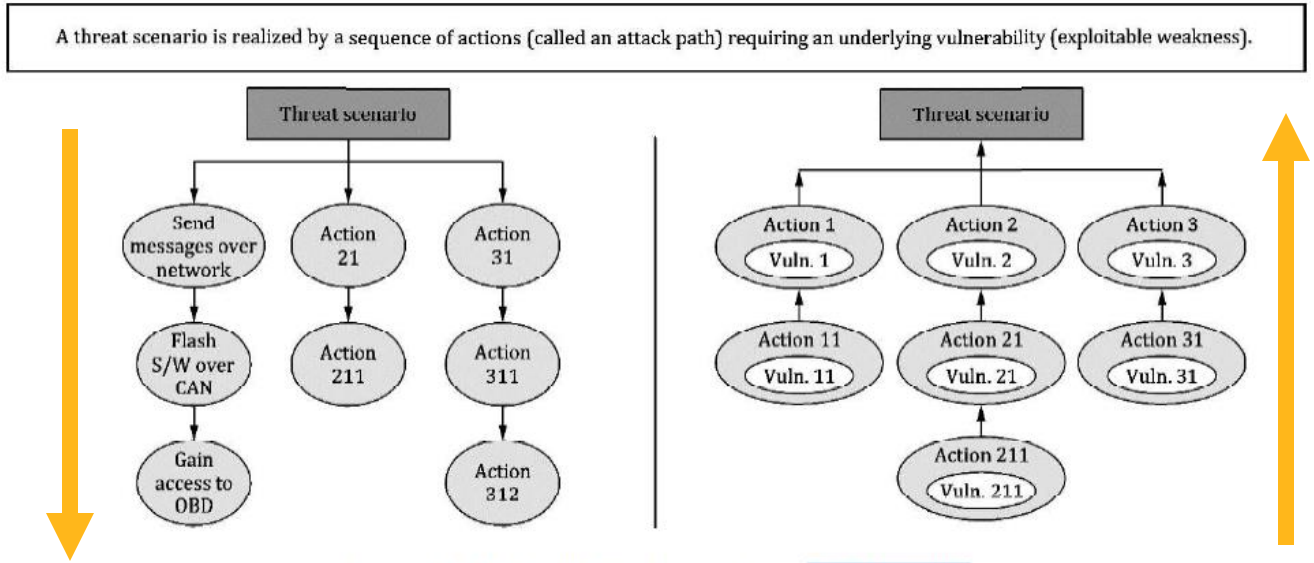


Figure 7 - Methods for determining attack paths

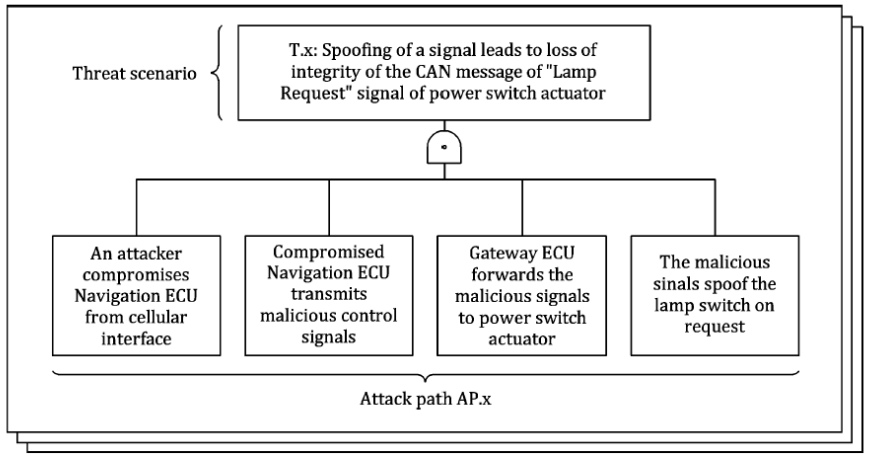
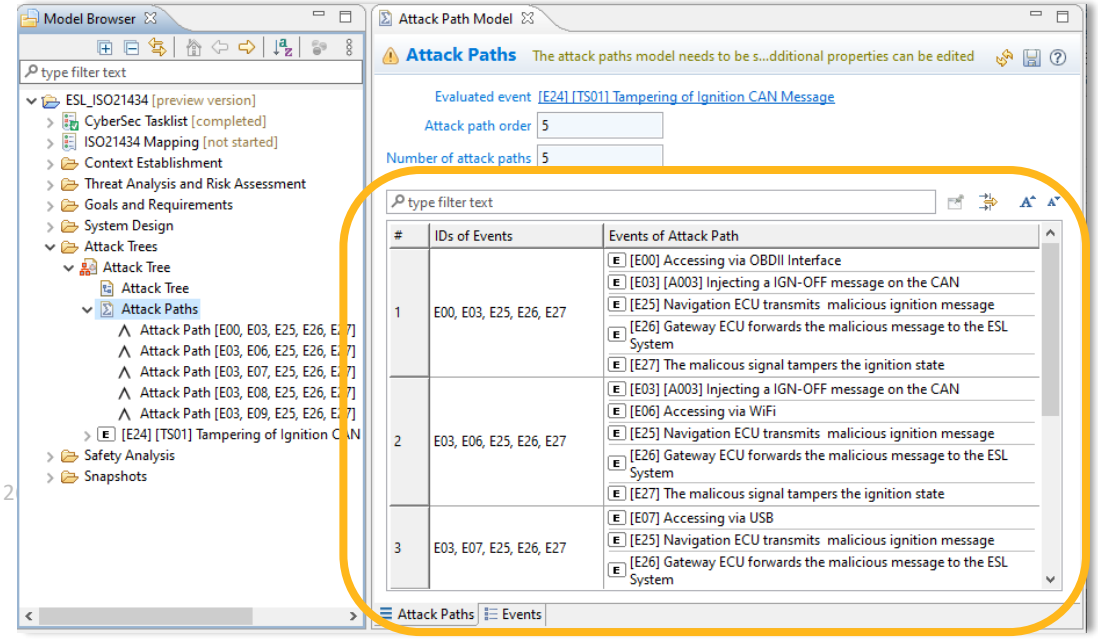


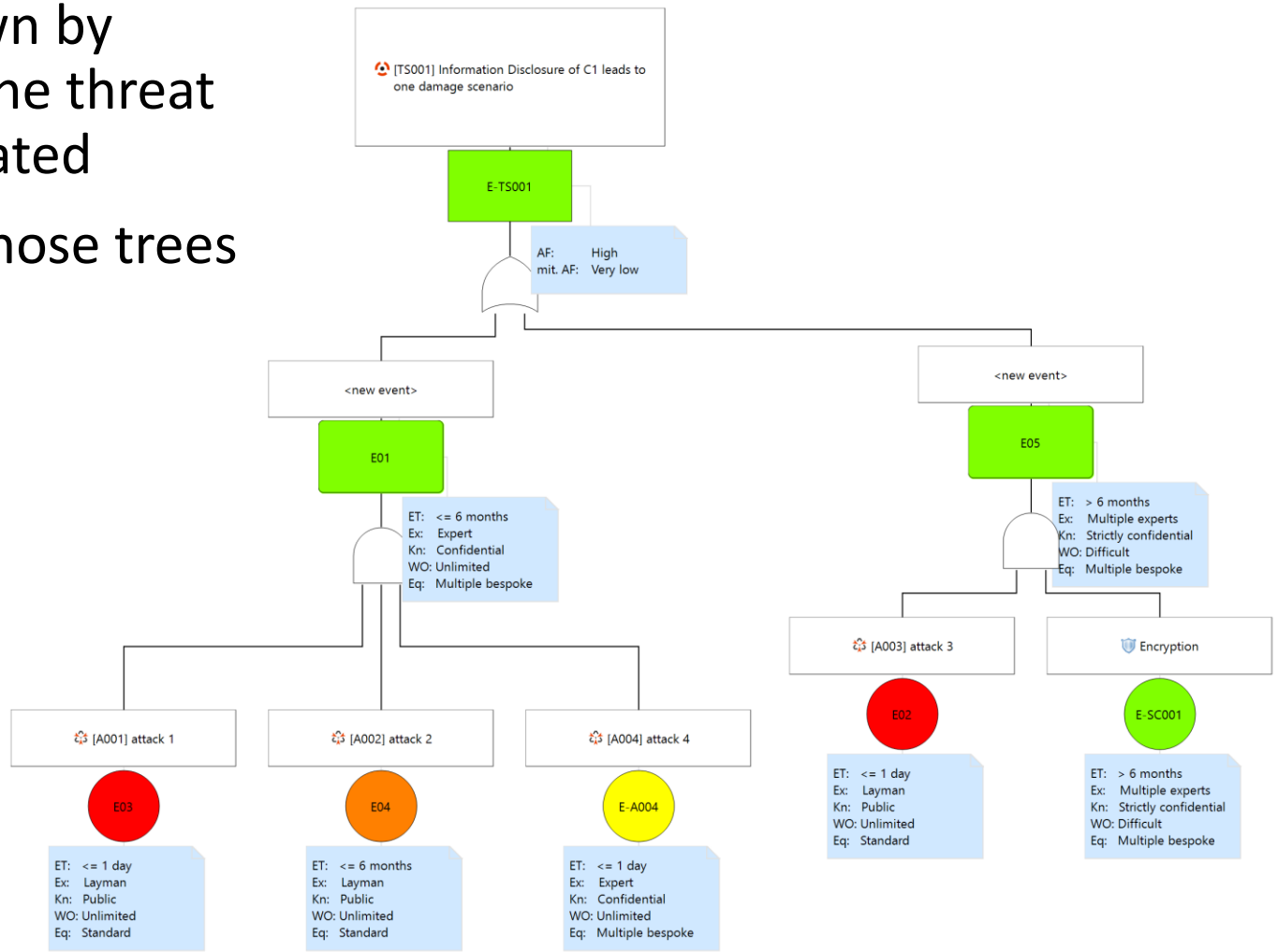
Figure G.5 - Example of an attack path derived by attack tree analysis

©2024 ANSYS, Inc.

medini analyze - Attack Path modelling (top down)

- attack scenarios are modelled top-down by means of an attack tree starting with the threat scenario, feasibility ratings are propagated
- Attack Paths are calculated based on those trees





©2024 ANSYS, Inc.

medini analyze - Attack Path modelling (bottom-up)

- vulnerabilities of the item are analyzed in a vulnerability analysis
- effects and exploiting attacks can be associated
- identified attacks can be aggregated in an attack tree that can be used to calculate attack paths

Vulnerability Analysis - ESL-Security

System SWA Worksheet

type filter text

Component/Function	Vulnerability	Vehicle Level Effect	Exploiting Attacks	Measures
ESL				
IGN : CAN				
Power : 12V				
ESL Controller	[V001] open port			
lock				
unlock				
IGN				
Ignition CAN Message	[V001] susceptible to manipulation	Integrity loss of integrity	Attacks [A001] Manipulation of the ignition message	Encryption
		Threat Scenarios [TS01] Tampering of Ignition CAN Message		
		Hazards and Top-Level Effects [HZ 1] Steering blocked		

©2024 ANSYS, Inc.

e) Attack Feasibility Analysis

- On the level of the identified attack paths

- Three methods of attack feasibility analysis are presented in ISO/SAE 21434 but need to be tailored:
  - Attack potential-based approach (see Annex I.3)
  - CVSS2 based approach (see Annex I.4)
  - Attack vector-based approach (see Annex I.5).

©2024 ANSYS, Inc.

e) Attack Feasibility Analysis based on Attack Potential

- Attack potential is rated in the following dimensions:
  - Time
  - Expertise
  - Knowledge of Target
  - Window of Opportunity
  - Equipment
- Every attack path resulting from the attack path analysis needs to be rated

©2024 ANSYS, Inc.

medini analyze Attack Feasibility Analysis - Rating

#	IDs of Events	Events of Attack Path	Approach	Elapsed Time	Expertise	Knowledge of item	Window of opportunity	Equipment	Attack vector	Attack complexity	Privileges required	User interaction	Attack Feasibility
1	E00, E03, E25, E26, E27	[E00] Accessing via OBDII Interface [E03] [A003] Injecting a IGN-OFF message on the CAN [E25] Navigation ECU transmits malicious ignition message [E26] Gateway ECU forwards the malicious message to the ESL System [E27] The malicous signal tampers the ignition state	potential-based	< 1 month	Proficient	Restricted	Easy	Standard					High
2	E03, E06, E25, E26, E27	[E03] [A003] Injecting a IGN-OFF message on the CAN [E06] Accessing via WiFi [E25] Navigation ECU transmits malicious ignition message [E26] Gateway ECU forwards the malicious message to the ESL System [E27] The malicous signal tampers the ignition state	CVSS						0.5	1.3	1	0.7	High

Attack Paths

©2024 ANSYS, Inc.

f) Risk Determination

- Done for every identified threat scenario
- Determined from
  - the **impact rating** of the associated **damage scenario** and
  - the **attack feasibility** of the associated **attack paths** (feasibilities from multiple paths should be aggregated appropriately)
- Risk level ranges from 1 (lowest) to 5 (highest)
- The calculus is not standardized (Annex J offers some examples)

©2024 ANSYS, Inc.

medini Analyze – Risk Determination

To allow this aggregated approach there are two columns:

- one that shows the damage scenarios caused by that threat scenario
- the other one showing the events representing that threat scenario as attack path

Risk Level are shown for every impact dimension

Risk Determination and Risk Treatment Decision

Risk Assessment ☑ Risk Treatment ☑

type filter text

ID	Threat	Asset	Damage Scenarios	Safety Impact	Financial Impact	Operational Impact	Privacy Impact	Impact Justification	Attack Paths	Attack Feasibility	Safety Risk	Financial Risk	Operational Risk	Privacy Risk
TE001	[TS01] Tampering of Ignition CAN Message	Ignition CAN Message	[DS01] Steering blocked resulting from loss of integrity of CAN Message Ignition [DS02] Steering not blocked resulting from loss of integrity of CAN Message Ignition	Severe	Moderate	Severe	Severe		Attack Path [E00, E03, E25, E26, E27]	High	5	3	5	5

©2024 ANSYS, Inc.

g) Risk Treatment

- A risk treatment option shall be determined considering impact categories, attack paths and the results from risk determination
- Options are (not mutually exclusive or appropriate in all circumstances):
  - Acceptance
  - Mitigation
  - Avoidance
  - Transfer
- For Threat Scenario with Risk Level 1 treatment may be omitted
- Security Goals can be associated with one or more threat scenarios
  - Typically, the protection of cybersecurity properties of assets whose compromise leads to an associated damage scenario

©2024 ANSYS, Inc.

medini analyze - Risk Treatment

Model Browser

type filter text

- ESL-ISO21434
  - CyberSec Tasklist [completed]
  - ISO21434 Mapping [not started]
  - Context Establishment
  - Threat Analysis and Risk Assessment
    - Safety Assessment
    - Security Assessment
      - Damage Scenarios
      - Threat Scenarios
      - Attacks
      - Threat Assessment
        - TE001

Treatment Options

type filter text

- [x] Avoidance
- [x] Mitigation
- [ ] Acceptance
- [ ] Transfer

Cybersecurity Goals are related as a top-level requirement

Risk Determination and Risk Treatment Decision

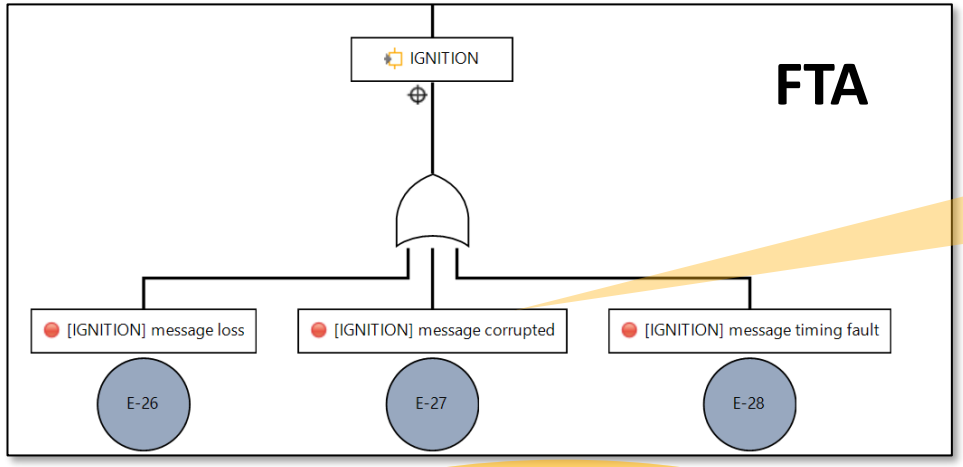
type filter text

ID	Threat	Asset	Safety Risk	Financial Risk	Operational Risk	Privacy Risk	Risk Acceptance Criterion	Treatment Options	Justification (Treatment)	Measures	Goal
TE001	[TS01] Tampering of Ignition CAN Message	Ignition CAN Message	5	3	5	5	[Low] for OEM	Avoidance Mitigation		Encryption	[CG001] Prevent the loss of integrity (CAL 4)

©2024 ANSYS, Inc.

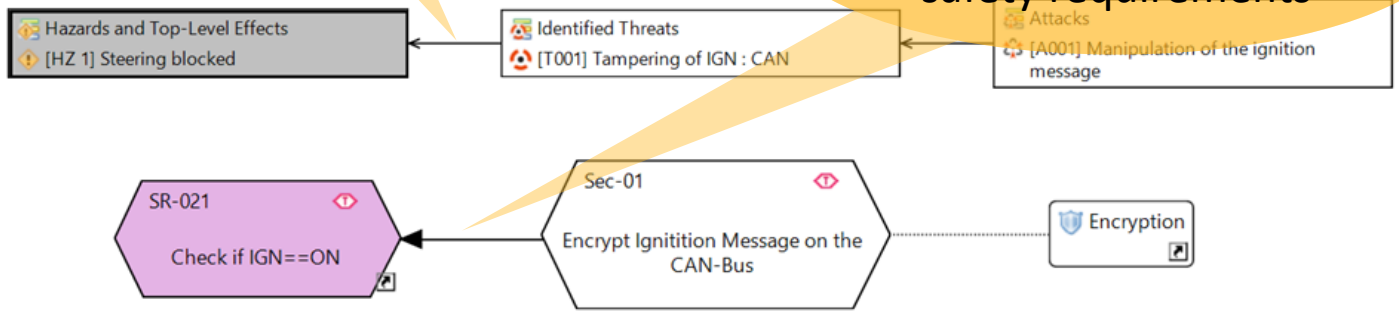
Which interfaces between Safety und Cyber Security make sense?

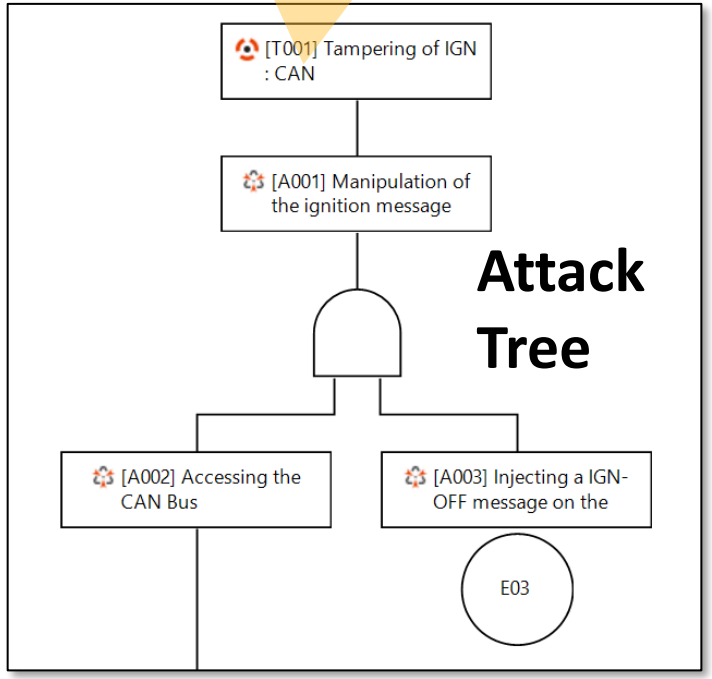
Cause-Effect-Relations express the impact of threats to safety hazards



Faults identified in an FTA can be a starting point for an Attack Tree

Security Requirements can contribute to safety requirements





The same System Model can be used in FuSa and Cyber Security!

©2024 ANSYS, Inc.

Conclusion

- Cybersecurity risk management is required – by standard and regulations but also in own interest
- Needs to be done systematically
- Is complex, as it addresses multiple dimensions
- Needs tool support to manage complexity
- Should be integrated with other activities (like safety analysis) and not in silo
- Needs to be a continuous activity

©2024 ANSYS, Inc.

Ansys Academic Program

- Spread the awareness and knowledge of medini analyze as the state-of-the-art tool for Functional Safety in all verticals amongst engineering students who are our future customers
- Address academic researchers and professors who influence the industry
- Embed medini analyze in the curricula of engineering courses of studies that will result in trained students joining the industries after they finished their studies

©2024 ANSYS, Inc.

Thank You!

www.ansys.com

Ansys